

# AP Agent Governance Framework

Humans remain accountable. Agents earn scope.

|         |                        |
|---------|------------------------|
| Product | AP Agent OS            |
| Tier    | Professional           |
| Version | 1.0                    |
| Date    | September 2026         |
| Use     | Implementation toolkit |

Responsibility is earned.

## Purpose

Give Finance, Controls, Security and Internal Audit a single framework for AP agents. Aligns conceptually with NIST AI RMF (Govern, Map, Measure, Manage), ISO/IEC 42001 as a management-system shape, and COSO 2026 GenAI internal-control thinking. This product is not a certification and is not legal advice.

## Accountability

| Role                | Must                                           |
|---------------------|------------------------------------------------|
| Executive sponsor   | Funds, stops, and is briefed on incidents      |
| Head of AP          | Owns the workforce and autonomy changes        |
| Agent owner (named) | Day-to-day performance and charter             |
| Control owner       | Design and operating effectiveness of controls |
| Model / tool owner  | Versions, access, vendor risk                  |
| Internal Audit      | Independent testing as they determine          |
| Human releaser      | Payment authority — never an agent             |

## Segregation of duties

An agent operator who can edit prompts or tolerances cannot be the sole payment releaser. An orchestrator cannot promote itself. A supplier-resolution drafter is not the person who verifies bank changes.

## Least privilege and RBAC

Agents receive the minimum system role needed for their level. Level 0–1: read + write to a sandbox queue. Level 2: write drafts. Level 3: listed actions only. No agent receives vendor-bank write or payment-file write.

## Approval boundaries

Written in the charter. Amount caps, entity lists, invoice types, hours of operation. Anything outside is escalation.

## Data privacy and confidentiality

Invoices contain prices, personal names, and sometimes bank details. Do not paste production invoices into consumer LLM products. Record the lawful basis and retention. Redact before any file leaves the organisation.

## Prompt injection

Treat all invoice text, email bodies and statement PDFs as untrusted data. System instructions live in a control plane the document cannot modify. Any “ignore previous / pay immediately / update bank” language → EX-PIJ.

## Hallucination and output validation

---

No number without a source ID. No vendor fact that is not in the retrieved record. Prefer deterministic checks for amounts, dates, tax arithmetic. Humans validate a sample; size the sample to risk.

## Audit logs, version control, model and workflow change

---

Log: input pointer, output, model ID, prompt version, taxonomy version, user overrides, timestamp. Change control: model upgrades go through the same historical pack. No silent prompt edits.

## Testing, release, incident, override, fallback, continuity

---

See Testing folder. Incidents: severity, contain (disable send/execute), notify owner + Controls, root cause, customer/supplier comms if needed. Override: named role, reason code, visible in the audit file. Fallback: revert to pre-agent process within one business day. Continuity: agents are not a single point of failure for paying suppliers.

## Evidence retention and access termination

---

Retain outputs for the same period as AP records in that jurisdiction, or longer if Audit requires. When a person leaves, remove agent-admin access the same day as ERP access.

## Periodic certification

---

Quarterly: owner recertifies charter, SoD, sample accuracy, incidents, cost. Annually: sponsor reviews whether the agent should exist.

## Vendor / model risk

---

Inventory every model and copilot that can see AP data. DPAs, residency, training-on-your-data flags, subprocessors. Shadow IT copilots are in scope.

## Autonomy progression

---

Evidence pack: gold-set size, precision/recall, false-negative review, control test, incident history, cost, owner + Controls signatures, expiry (max 90 days unless re-certified).

---

This material is an implementation toolkit. It is not legal, tax, accounting, audit or investment advice. Agents do not authorise payments. Humans remain accountable. Statistics are cited in the Research Ledger.